File Path Traversal

File Inclusion Vulnerabilities (LFI/RFI) &

File Upload Vulnerabilities

Introduction

File Path Traversal

It is a form of filesystem attack that allows an attacker to access files, directories and commands that potentially reside outside the root directory.

File Inclusion

This is a type of vulnerability that is commonly found in web applications that rely on a scripting run time, and occur when a web application allows users to submit input into files or upload files to the server.

It allows an attacker to read and sometimes execute files on the victim server. In case of Remote File inclusion, it allows the attacker to execute code hosted on the attacker's machine.

What can an attacker do with File Path Traversal?

When the attacker has access to application source code / configuration, critical system files, an attacker can manipulate a URL so the application will execute/reveal the contents of arbitrary files on the server.

Any device / application that exposes an HTTP-based interface is potentially vulnerable to Path traversal attack.

Types of File Inclusion

- **Local File Inclusion**
  - This is basically when the file that is included happens to be a local file. A local file meaning a file that is local to the web server. For example: /etc/passwd file that exists in the web server's operating system.
- **Remote File Inclusion**
  - Here the file included doesn't exist on the server but somewhere on the web. For example: "http://google.com" points to index.html on google's servers.
  - RFI can be used for command injection and reverse shll attacks.

Testing Methodology

To test for file path traversal attack. Take a url and check if it accepts any parameters. For example, a url that ends with "?id=343" indicates that the url has a parameter "id" that has value "343" assigned to it.

Now, look for such parameters that seem to accept values in the form of file paths. For example, "?filename=fastly.png"

https://example.com/?filename=fastly.png

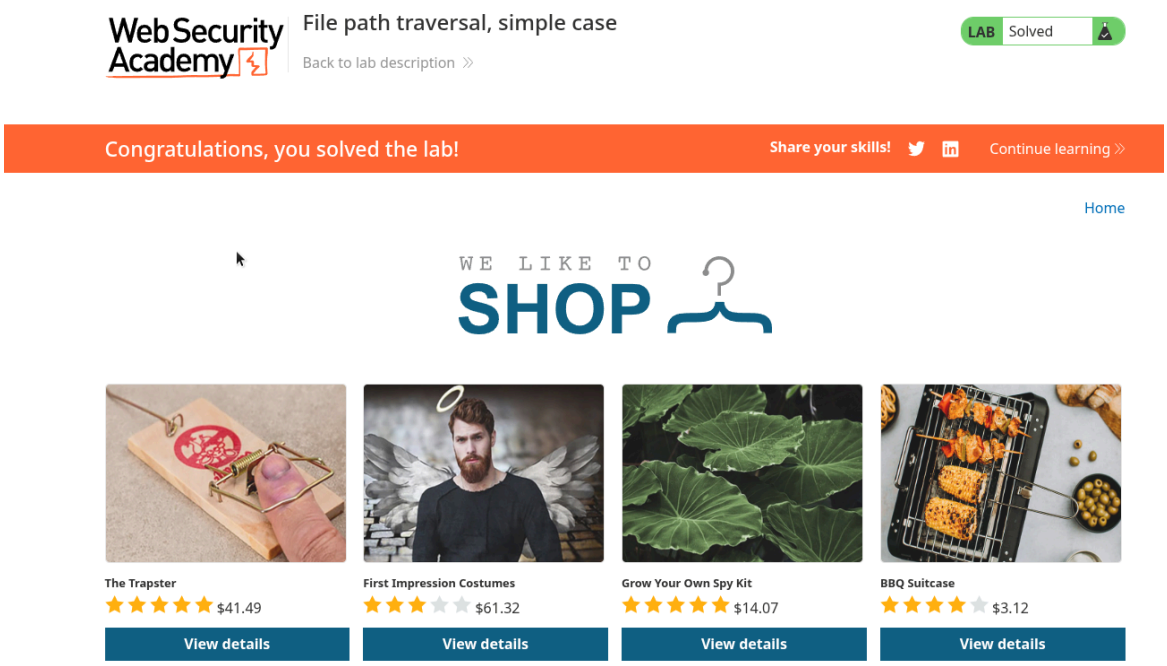
Finally, try to see if you get surprising results when the value is changed to a path pointing to secret files.

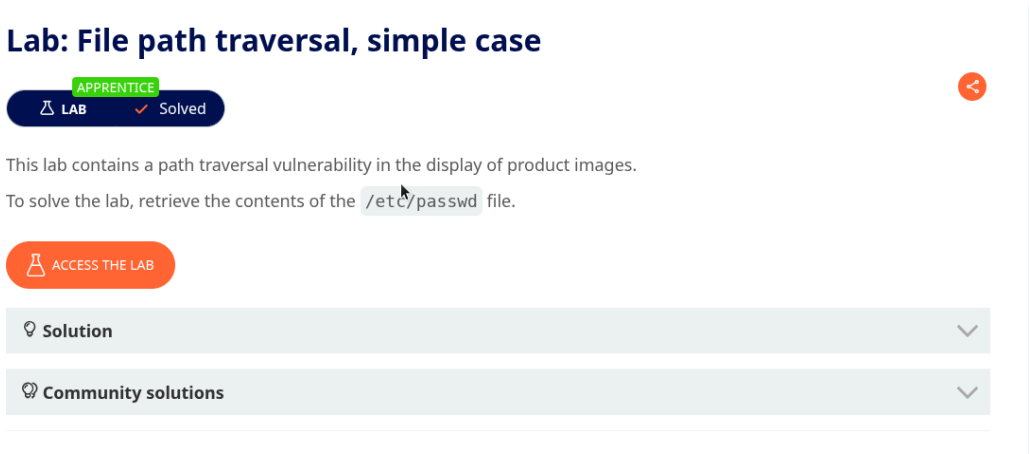
https://example.com/?filename=../../../etc/passwd

Practical (Lab)

Completed labs related to File Path Traversal at PortsWigger

https://portswigger.net/web-security/file-path-traversal





Web Security Academy

File path traversal, traversal sequences blocked with absolute path bypass

LAB Solved

Back to lab description »

Congratulations, you solved the lab!

Share your skills! Continue learning »

Home

WE LIKE TO SHOP

Hitch A Lift

$82.49

View details

Sprout More Brain Power

$97.26

View details

Conversation Controlling Lemon

$55.09

View details

Folding Gadgets

$59.42

View details

Lab: File path traversal, traversal sequences blocked with absolute path bypass

PRACTITIONER

LAB Solved

This lab contains a path traversal vulnerability in the display of product images.

The application blocks traversal sequences but treats the supplied filename as being relative to a default working directory.

To solve the lab, retrieve the contents of the `/etc/passwd` file.

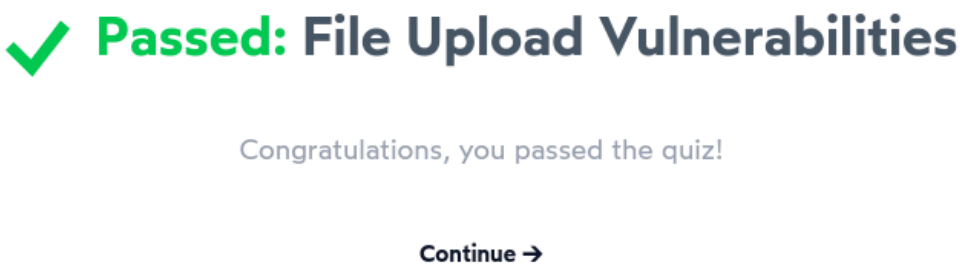
ACCESS THE LAB

Solution

Community solutions

Completed the following lab related to File Upload Vulnerability

https://www.hacksplaining.com/exercises/file-upload



Conclusion

Based on the analysis of File Path Traversal, File Inclusion, and File Upload vulnerabilities, it is clear that these are security flaws that allow attackers to gain unauthorized access to the server's filesystem, configuration, and grant the ability to execute arbitrary code.

File Path Traversal enables access to critical system files outside the root directory, while Local File Inclusion (LFI) and Remote File Inclusion (RFI) allow the reading or execution of files, with RFI specifically facilitating command injection and reverse shell attacks from a remote location.

The testing methodology for these vulnerabilities is straightforward, often involving manipulating URL parameters that handle file paths.

The completion of practical labs confirms the serious nature of these attacks and highlights the need for robust input validation, proper file handling, and secure configuration to mitigate the risks associated with these fundamental web application vulnerabilities.